# SECURITY ASSESSMENT AND VULNERABILITY ANALYSIS REPORT

## EXECUTIVE SUMMARY

This report presents the findings of a Vulnerability Assessment conducted on a controlled virtual environment. The assessment identified multiple critical and high-risk vulnerabilities, including outdated services, insecure protocols, and misconfigurations.

Key risks include the presence of a vulnerable FTP service (vsftpd 2.3.4) with a known backdoor, the use of Telnet for remote access, and an outdated Apache web server. These vulnerabilities significantly increase the risk of unauthorized access, data exposure, and system compromise.

The assessment was performed using tools such as Nmap and Nikto to identify open ports, service versions, and web application weaknesses. Based on the findings, appropriate remediation measures are recommended, including disabling insecure services, applying security patches, and improving system configurations.

Overall, the system requires immediate attention to mitigate critical risks and enhance its security posture.

## INTRODUCTION:

Modern information systems operate within complex networked environments where even minor misconfigurations can expose critical assets to compromise. This report presents a structured Vulnerability Assessment and Penetration Testing (VAPT) exercise conducted on a controlled virtual target to identify security weaknesses at the network and application levels. The assessment leverages active reconnaissance techniques, including service enumeration and web server analysis, to uncover exposed services, outdated software components, and insecure configurations. Tools such as Nmap and Nikto were utilized to systematically analyze the attack surface and validate potential risks. The objective of this exercise is to provide a clear understanding of identified vulnerabilities, assess their potential impact using standardized risk metrics, and recommend practical remediation measures. All testing activities were performed within an authorized lab environment to ensure compliance with ethical and safe security practices.

## OVERVIEW

- Conduct detailed network reconnaissance to identify active hosts, open ports, and running services
- Perform vulnerability scanning to detect outdated software, insecure protocols, and misconfigurations
- Analyze identified vulnerabilities to understand potential attack vectors and impact
- Evaluate risk levels using standardized scoring approaches such as CVSS
- Recommend effective remediation strategies to strengthen the overall security posture

## TARGET DESCRIPTION

The target system selected for this assessment is a deliberately vulnerable virtual machine deployed within a controlled lab environment to simulate real-world security weaknesses. The system is hosted on a local virtual network, enabling safe and authorized testing without impacting external infrastructure.

The assessment was performed from a Kali Linux machine configured within the same network, ensuring direct communication with the target. The primary objective was to identify exposed services, analyze running versions, and evaluate potential vulnerabilities associated with misconfigurations and outdated components.

• Target IP Address: 192.168.190.129

• Environment: Local virtual network (VMware)

• Scanner System: Kali Linux (Attacker Machine)

• Assessment Type: Authorized internal vulnerability assessment

## METHODOLOGY

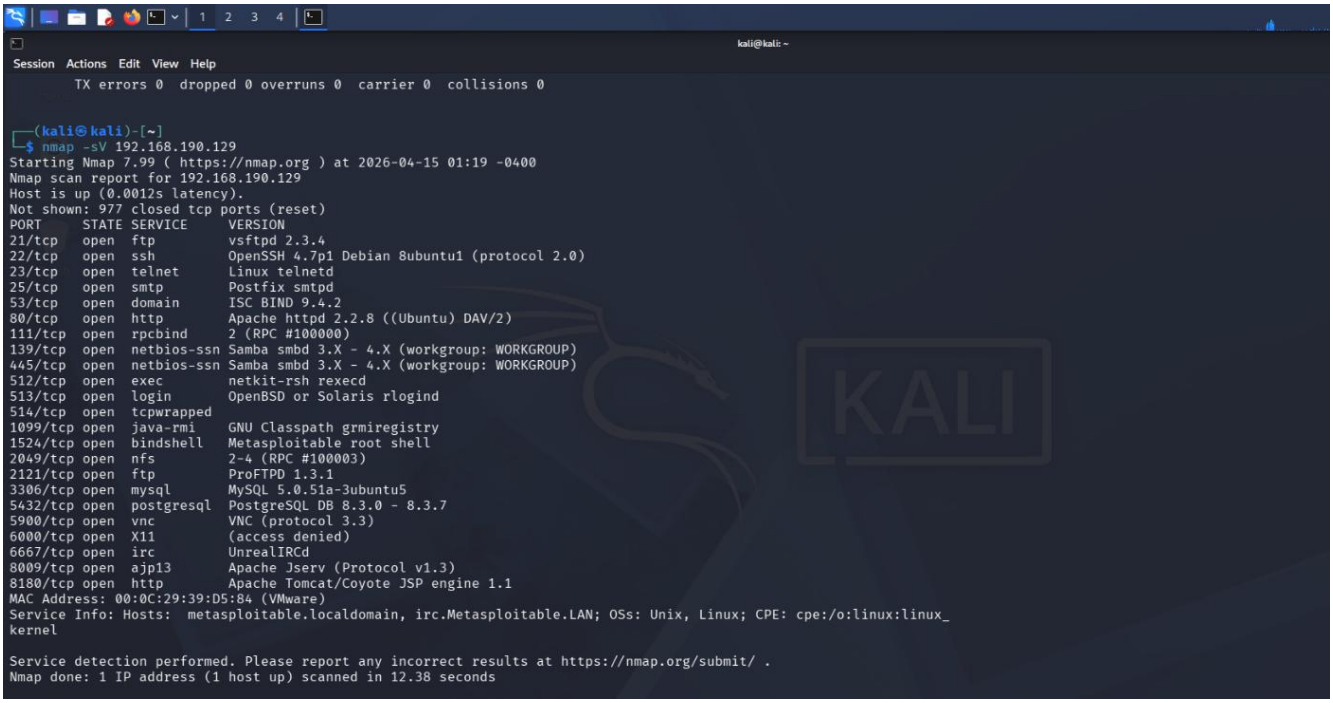
The assessment was conducted using a structured and systematic approach to ensure accurate identification and analysis of vulnerabilities within the target environment.

## INITIAL ENVIRONMENT VALIDATION

Preliminary checks were performed to verify the operational status of the testing environment and tools. Network connectivity between the attacker machine (Kali Linux) and the target system was confirmed to ensure reliable communication during scanning activities. This step ensured that all required tools were functioning correctly and that the testing environment was properly configured for assessment.

## NETWORK DISCOVERY AND ENUMERATION

Active reconnaissance was carried out using Nmap to identify open ports, running services, and service versions on the target system. This phase provided a clear understanding of the exposed attack surface and potential entry points. The information gathered during this stage forms the foundation for further analysis and vulnerability identification.



```
Session  Actions  Edit  View  Help
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.190.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-15 01:19 -0400
Nmap scan report for 192.168.190.129
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:39:D5:84 (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_
kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.38 seconds
```

***Figure 1:*** *Nmap scan output showing open ports and service versions*

## SERVICE IDENTIFICATION AND VERSION DETECTION

Detailed service enumeration was performed to determine the exact versions of services running on open ports. This information is critical for mapping known vulnerabilities associated with outdated or misconfigured services. By identifying specific service versions, it becomes possible to correlate them with publicly disclosed vulnerabilities and known exploits from databases such as the National Vulnerability Database (NVD). This process enhances the accuracy of vulnerability assessment and helps prioritize remediation efforts based on the severity and exploitability of each identified issue.

## WEB SERVER VULNERABILITY ASSESSMENT

Nikto was utilized to assess the web server for common vulnerabilities, including insecure configurations, missing security headers, and outdated components. This helped identify weaknesses at the application layer that may not be visible through network scanning alone. The results provided insights into potential web-based attack vectors and misconfigurations.

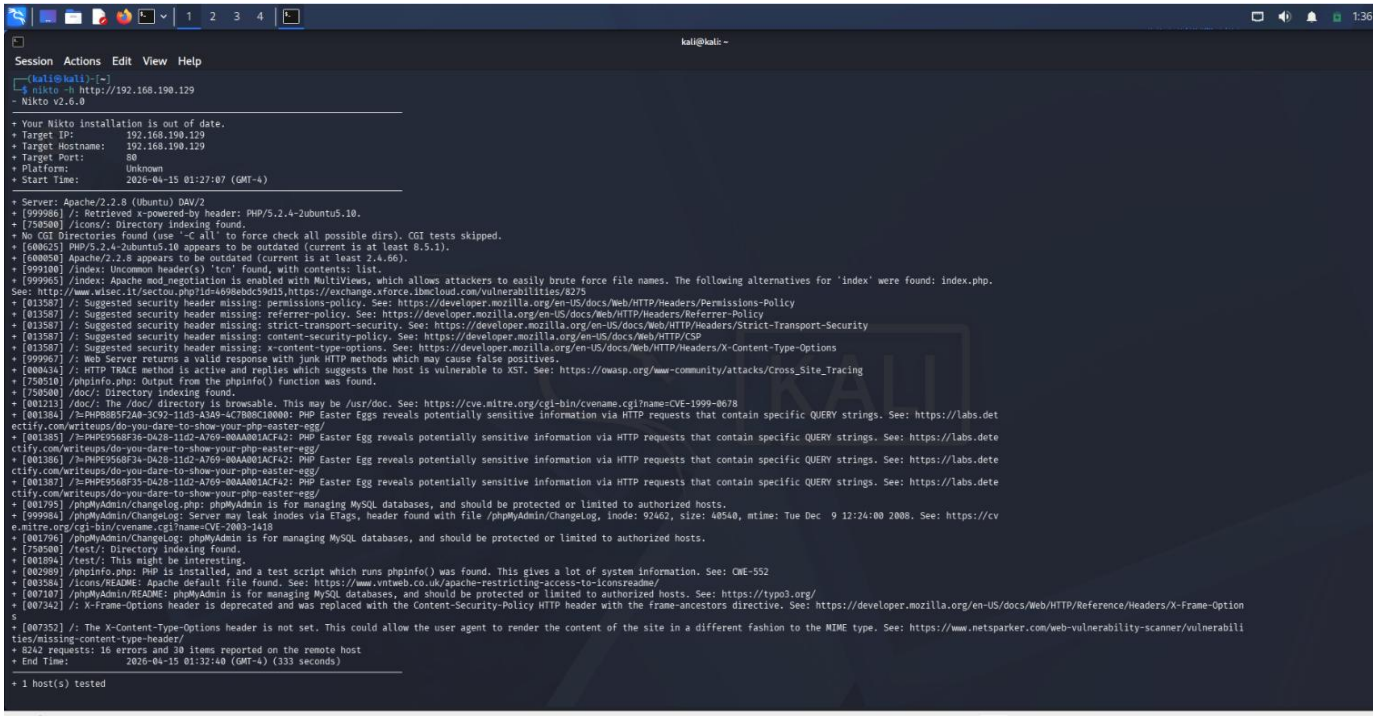



***Figure 2:*** *Nikto scan output showing web server vulnerabilities*

## VULNERABILITY ANALYSIS AND RISK EVALUATION

The identified vulnerabilities were analyzed to determine their severity and potential impact on the system. Standard risk evaluation practices, including CVSS-based scoring, were used to prioritize findings. This step ensures that critical vulnerabilities are addressed first, reducing the overall risk to the system.

## OPENVAS ATTEMPT AND CONSTRAINTS

An attempt was made to perform automated vulnerability scanning using OpenVAS (GVM). However, due to feed synchronization issues and network-related constraints, the scan could not be completed. As a result, manual analysis using Nmap and Nikto was used to ensure comprehensive coverage.

## RESULTS AND ANALYSIS

The vulnerability assessment identified multiple open ports and associated services running on the target system. These services were further analyzed to determine potential security weaknesses and exposure levels.

## SCAN RESULTS SUMMARY

The network scan revealed several active services, including FTP, SSH, Telnet, and HTTP. Among these, certain services were identified as outdated or inherently insecure, increasing the risk of exploitation.

| PORT | PROTOCOL | STATE | SERVICE | VERSION | DESCRIPTION |
|---|---|---|---|---|---|
| 21 | TCP | Open | FTP | vsftpd 2.3.4 | Known backdoor vulnerability |
| 22 | TCP | Open | SSH | OpenSSH | Secure remote access service |
| 23 | TCP | Open | Telnet | - | Unencrypted remote login |
| 80 | TCP | Open | HTTP | Apache 2.2.8 | Outdated web server |

## ANALYSIS

The presence of outdated and insecure services significantly increases the attack surface of the system. The FTP service (vsftpd 2.3.4) is particularly critical due to its known backdoor vulnerability, which can allow unauthorized remote access.
The Telnet service poses a high risk as it transmits data, including credentials, in plain text, making it susceptible to interception attacks. Additionally, the Apache web server is outdated, which may expose the system to known exploits and web-based attacks.
Web application scanning further identified issues such as HTTP TRACE method enabled and missing security headers, indicating poor security configuration at the application level.
These combined weaknesses create multiple potential entry points for attackers, increasing the likelihood of exploitation through both network-based and application-layer attacks. If left unaddressed, these vulnerabilities could lead to data breaches, unauthorized privilege escalation, and service disruption. Furthermore, the lack of proper security hardening indicates insufficient defensive measures, making the system an attractive target for automated and manual attacks.
Overall, the system demonstrates multiple security weaknesses that could be leveraged by an attacker to gain unauthorized access or disrupt services.

## RISK ASSESSMENT

The identified vulnerabilities were evaluated based on their potential impact and likelihood of exploitation. CVSS (Common Vulnerability Scoring System) scores were used to quantify the severity of each vulnerability.

| ISSUE | RISK LEVEL | CVSS SCORE | DESCRIPTION | MITIGATION |
|---|---|---|---|---|
| vsftpd Backdoor | Critical | 10.0 | Allows unauthorized remote access to the system | Disable or update FTP service |
| Telnet Service | High | 7.5 | Transmits credentials in plain text | Disable Telnet and use SSH |
| Outdated Apache | High | 7.5 | Vulnerable to known exploits | Update to latest version |
| HTTP TRACE Enabled | Medium | 4.3 | Enables Cross-Site Tracing attacks | Disable TRACE method |
| Missing Security Headers | Low | 3.1 | Weakens browser-side protection | Implement security headers |

## REMEDIATION

The following remediation measures are recommended to address the identified vulnerabilities:

• Update FTP Service: Replace or disable vsftpd 2.3.4 and use a secure file transfer mechanism such as SFTP.

• Disable Telnet: Replace Telnet with SSH to ensure encrypted communication.

• Update Apache Server: Upgrade Apache to the latest stable version to mitigate known vulnerabilities.

• Disable HTTP TRACE: Configure the web server to disable the TRACE method to prevent Cross-Site Tracing attacks.

• Implement Security Headers: Add headers such as Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options.

• Restrict Access: Limit access to sensitive services and directories using firewall rules and authentication mechanisms.

Applying these fixes will significantly reduce the attack surface and improve overall system security.

## SERVICE RESEARCH

### 1. FTP (Port 21)

File Transfer Protocol (FTP) is used for transferring files between systems. The detected version (vsftpd 2.3.4) contains a well-known backdoor vulnerability.

## SECURITY RISKS:

• Unauthorized remote access

• Remote command execution

• Complete system compromise

**Example** Vulnerability: CVE-2011-2523

### 2. HTTP (Port 80)

Hypertext Transfer Protocol (HTTP) enables communication between web clients and servers. The detected Apache version is outdated and may contain multiple known vulnerabilities.

Security Risks:

• Cross-Site Scripting (XSS)

• SQL Injection

• Directory traversal

**Example** Vulnerability: CVE-2021-41773

### 3. Telnet (Port 23)

Telnet is an insecure remote access protocol that transmits data in plain text without encryption.

Security Risks:

• Credential interception

• Man-in-the-middle attacks

• Unauthorized access

### 4. SSH (Port 22)

Secure Shell (SSH) provides encrypted remote access. Although secure by design, outdated versions may still pose risks.

Security Risks:

• Brute-force attacks

• Weak authentication configurations

The analysis of these services highlights the importance of secure configurations and regular updates to prevent exploitation of known vulnerabilities.

## OPENVAS ANALYSIS

An attempt was made to perform automated vulnerability scanning using OpenVAS (Greenbone Vulnerability Manager) to obtain detailed vulnerability insights, including CVE references and CVSS scores.

However, during the setup and feed synchronization process, multiple technical issues were encountered, including rsync timeout errors and feed download failures. These issues persisted despite troubleshooting efforts such as VPN usage, reconfiguration, and repeated synchronization attempts.

Due to these constraints, the OpenVAS scan could not be completed successfully. As a result, vulnerability assessment was conducted using alternative tools such as Nmap and Nikto, which provided sufficient data for identifying and analyzing security weaknesses.

This scenario reflects real-world challenges where tool limitations or environmental constraints may require analysts to rely on multiple tools and manual analysis techniques.

## NETWORK DIAGRAM

The testing environment consists of a virtualized network setup where the attacker and target systems are hosted within the same isolated network.

- Kali Linux (Attacker Machine): Used for performing scanning and analysis
- Metasploitable (Target Machine): Deliberately vulnerable system
- Network Type: Virtual local network (VMware)

The attacker machine communicates directly with the target system to perform reconnaissance and vulnerability assessment using tools such as Nmap and Nikto. This controlled setup ensures safe and authorized testing without affecting external systems.

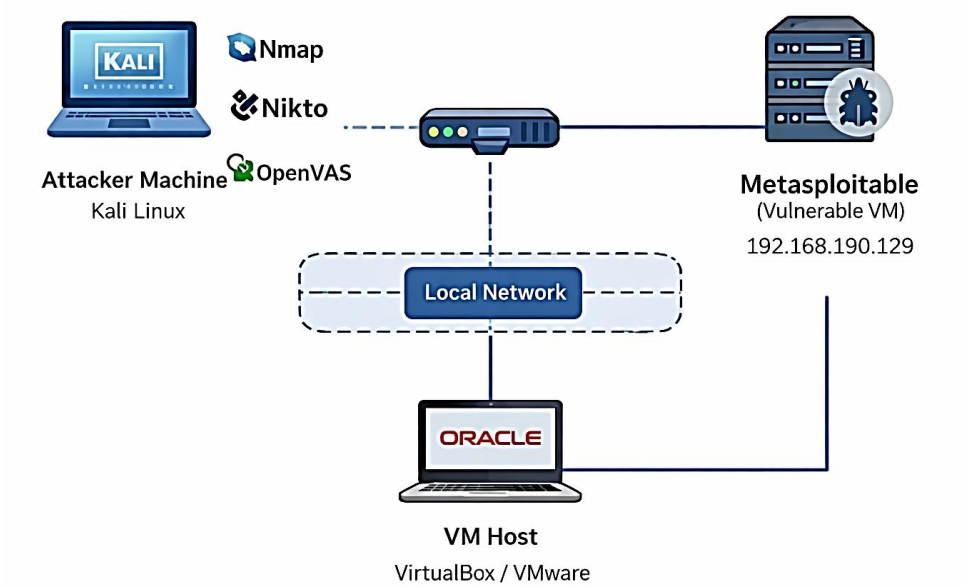



***Figure 3:*** *Network diagram of Kali Linux attacker and Metasploitable target in a virtual lab environment.*

## CONCLUSION

The vulnerability assessment successfully identified multiple security weaknesses within the target system, including outdated services, insecure protocols, and misconfigurations. Critical vulnerabilities such as the FTP backdoor and the presence of Telnet significantly increase the risk of system compromise.

The findings emphasize the importance of maintaining updated software, disabling insecure services, and implementing proper security configurations. Regular vulnerability assessments and continuous monitoring are essential to detect and mitigate emerging threats.

Overall, this exercise provided practical exposure to real-world security assessment techniques and reinforced the importance of systematic analysis, risk evaluation, and professional reporting in cybersecurity practices.

## REFERENCES

- https://nmap.org
- https://owasp.org
- https://cve.mitre.org
- https://greenbone.net